



File No.: EXP202412881

RESOLUTION FOR TERMINATION OF THE PROCEDURE BY RECOGNITION OF RESPONSIBILITY AND VOLUNTARY PAYMENT

From the procedure initiated by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: On February 3, 2025, the Presidency of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against IBERMUTUA, COLLABORATIVE MUTUAL WITH SOCIAL SECURITY NO. 274 (hereinafter, IBERMUTUA), by means of the agreement transcribed below:

<<

File No.: EXP202412881

AGREEMENT TO INITIATE SANCTIONING PROCEEDINGS

From the actions taken by the Spanish Agency for Data Protection and based on the following

FACTS

FIRST: On the dates 01/08/2024, 09/08/2024, again 09/08/2024, 21/08/2024, 22/08/2024, 26/08/2024, and 06/09/2024, several complaints were filed with the Spanish Agency for Data Protection regarding the same facts, concerning a possible infringement attributable to IBERMUTUA COLLABORATIVE MUTUAL WITH SOCIAL SECURITY NO. 274 with NIF G81939217 (hereinafter, IBERMUTUA).

The complainants state that they received a communication sent by the Data Protection Officer (DPO) of IBERMUTUA informing them that due to a computer error, personal data, including health data, had been sent to different companies and entities, with which IBERMUTUA had contacted for their deletion. Along with the complaints, they provided the submitted writings.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter LOPDGDD), the complaint was forwarded to IBERMUTUA for analysis and to inform this Agency within one month of the actions taken to comply with the requirements set forth in the data protection regulations.

The notification of the transfer of the complaint, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was made on 01/10/2024 as recorded in the acknowledgment of receipt in the file.

On 04/11/2024, a response was received by this Agency, indicating the following:

That Ibermutua Digital Empresas/Asesorías is an online platform aimed at companies that collaborate in managing procedures before IBERMUTUA (Collaborative Mutual with Social Security). Its main purpose is to digitize and facilitate the management of procedures and inquiries related to economic benefits borne by IBERMUTUA, of which workers in user companies of the platform are beneficiaries.

On 15/07/2024, a user company of the platform informed IBERMUTUA that in a weekly notification email regarding the labor absences of its employees, attached files contained data relating to individuals outside its company. Following this communication, a human error was detected in the programming of the sending of attached files in emails sent from the platform, in which Excel files containing information about employees from other companies and entities had been concatenated and attached.

Specifically, a comment was added to a line of code that caused the attached Excel file to reset with each new notification. The introduction of a comment prevents the line of code from executing and, consequently, in each sending, the previous files generated on the same day and directed to other recipients are added.

The incident affects the data of 3,395 individuals, whose data was sent to a total of 354 recipients from companies and advisory firms collaborating with IBERMUTUA. The information included the following personal data (the response details the number of individuals from whom each of these data was leaked):

- Name and surname
- NIF/NIE

- Social Security affiliation number (NAF)
 - Age
 - Type of contingency (related to their economic benefit from Social Security)
 - Whether it was a case of sick leave or not
 - Date of sick leave
 - Date of return to work
 - Number of days of sick leave up to the date of notification
 - Company of the worker
 - Reason for return
 - Expected days of sick leave
 - Regulatory Base for calculating the economic benefit
 - Total or partial cost of the process
 - Approximate contribution cost
 - CNO (National Occupation Code) of the worker
 - Whether or not there is a waiting period to be entitled to the economic benefit
- 3/18
- Whether it is a work accident in itinere
 - Whether it is a traffic accident
 - Sex (M or F)

IBERMUTUA states that after detecting the breach, it took the following actions:

- Immediate technical measures:
 - o Correction of the error in the program and establishment of a series of exhaustive tests to verify the correct functioning of any future changes.
 - o Restriction of attachments so that the system does not allow the sending of multiple attachments in a single email.
 - o Verification of the attachment ID with the corresponding recipient.
 - o Pre-sending tests of email batches with a sample.
- Immediate operational measures: contacted the 354 recipient entities due to the erroneous information for them to proceed with its deletion. IBERMUTUA followed up on the confirmation from these entities regarding the deletion of their data, completing that process on 06/09/2024.
- The breach was documented and reported to the AEPD on 17/07/2024.
- Affected individuals were informed via email or postal mail.

Additionally, IBERMUTUA reports on the security measures of the treatments adopted prior to the incident detailing:

- Security measures (architecture, technologies used, security, and traceability)
- Organizational measures
 - o Privacy statement regarding personal data
 - o Procedure for personnel obligations in information security and data protection, mandatory for all personnel.
- Operational measures
 - o Training measures for its staff, particularly regarding data protection
- Risk analysis, providing supporting documentation of the risk analyses conducted, particularly regarding the treatment "economic benefits" and the treatment "relationship with mutualist companies," in which no high risk to the rights and freedoms of the interested parties was evidenced.
- Furthermore, it states that in July 2024, an external audit on data protection began, which included conducting risk analyses and impact assessments of eight of Ibermutua's treatments, including those affected in the present case. However, the date of this audit is not recorded, nor does IBERMUTUA attach documentation regarding it.

Finally, IBERMUTUA informs of the measures it intends to adopt to prevent a similar incident from occurring in the future:

“Technical measures.

Objective

Implement a system in AWS that securely manages the generation of document download links. The new system will focus on ensuring that:

- The generated links are protected by security levels and restricted access.
- The possibility of data cross-errors is minimized through additional controls and audits.
- A complete record of accesses and actions performed on the documents is maintained.

Components.

The new system will consist of the following key components:

- API Gateway: Entry point for HTTP requests (upload and download of documents).
- AWS Lambda: Functions responsible for business logic:
- Document upload: Receives the document, stores it in S3, and saves the metadata (hash, security levels, expiration, etc.).
- Document download: Verifies the hash, expiration, and security of the document, and if valid, generates the download response.
- Amazon S3: Secure storage of documents.
- CloudWatch: Access logging, error control, and real-time auditing.
- Audit Session: Store information about the IPs accessing the documents, when they do so, and the validity of the accesses (including failed attempts).

Key Functions.

- Security in download: An appropriate level of security will be required to access the document, such as a PIN based on the sensitivity of the document.
- Error management: In case of an error in the download, the system will return a detailed error message, with an error log in CloudWatch for review.
- Automatic expiration: Documents will be deleted from S3 after the expiration time, minimizing the risk of long-term exposure.

Operational measures.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/18

- The incident recorded with reference number DAU-136933 has been logged in the Ibermutua platform designated for this purpose, Jira-Service Desk.
- Once the security breach occurred and the risk of technical and human errors was materialized, affecting the dimension of confidentiality, a review of the risk analyses regarding data protection has been carried out for both the processing of 'Economic Benefits' and the so-called 'Relationship with Mutual Companies.'

Attached to your response is the following documentation:

- Communications made to the recipient entities due to erroneous information, as well as their confirmations of having deleted the data.
- Communications to the affected individuals.
- User guide for Ibermutua Digital Empresas / Consultancies.
- Documentation regarding the communication of the breach to the AEPD.
- Internal manual of procedures regarding information security and privacy.
- Informational materials on security and data protection for your staff.
- Risk analyses and assessments of necessity and proportionality of the processing operations subject to this procedure.
- ENS valuation form of the information system of IBERMUTUA.
- Reports on data protection impact assessments of the processing operations subject to this procedure.

- Record of processing activities of the company.

THIRD: On 29/11/2024, in accordance with Article 65 of the LOPDGDD, the mentioned claims were admitted for processing. On 21/10/2024, a new claim regarding the same facts was received and admitted for processing on 10/12/2024.

FOURTH: According to the report collected from the AXESOR tool, the entity IBERMUTUA is a company established in 1992, with a business volume of (...) euros in 2023.

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and the guarantee of digital rights (hereinafter, LOPDGDD), the Presidency of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/18

II

Procedure

Furthermore, Article 63.2 of the LOPDGDD states that: "The procedures processed by the Spanish Agency for Data Protection will be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures."

In accordance with Article 64 of the LOPDGDD, and taking into account the characteristics of the alleged infringement committed, a sanctioning procedure is initiated.

The procedure will have a maximum duration of twelve months from the date of the initiation agreement. After this period, it will expire, and consequently, the proceedings will be archived, in accordance with the provisions of Article 64 of the LOPDGDD.

If no allegations are made regarding this initiation agreement within the stipulated period, it may be considered a proposal for resolution, as established in Article 64.2.f) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP).

III

Preliminary Issues

In this case, in accordance with the provisions of Articles 4.1 and 4.2 of the GDPR, it is noted that there has been processing of personal data, since IBERMUTUA carries out, among other operations, the collection, registration, conservation, structuring, and communication through the aforementioned platform of data of natural persons. Specifically, regarding this procedure: name and surname, NIF, NIE, Social Security affiliation number (NAF), age, sex, data related to economic benefits from Social Security and the contingencies that give rise to them (reasons and dates of labor leave and returns, accidents, etc.) and data on labor relations (employer, occupation, contribution bases, etc.)

The operational framework within which the processing is carried out is as follows: IBERMUTUA is a collaborating mutual of Social Security and, as such, manages certain benefits (work accidents, occupational diseases, etc.) Companies and consultancies (management firms, offices, etc.) can associate with IBERMUTUA so that it manages the benefits of which their workers (or workers of their clients, in the case of consultancies) are beneficiaries. For the management of these benefits, IBERMUTUA collects and processes personal data of these workers.

Among the services offered to associated companies and consultancies, IBERMUTUA has a digital platform called Ibermutua Digital. This platform, among other functionalities, provides its associates with information on the status of their workers' benefits, which includes the aforementioned data. This information can be accessed in different formats, one of which, the subject of...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
7/18

this procedure involves sending a weekly, configurable email to companies and consultancies that contains an Excel file with the information (and the aforementioned personal data) corresponding to the employees of the associated company or consultancy.

IBERMUTUA carries out this activity in its capacity as data controller, as it is the one who determines the purposes and means of such activity, pursuant to Article 4.7 of the GDPR, as it is the one who determines the purposes and means of processing.

IV

Obligation Breached. Integrity and Confidentiality

Letter f) of Article 5.1 of the GDPR states:

"1. Personal data shall be:

(...)

f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction or damage, by applying appropriate technical or organizational measures ('integrity and confidentiality')."

In this case, it has been established that on 15/07/2024, IBERMUTUA became aware of a personal data breach, which the company itself reported to this Agency on 17/07/2024. The breach consists of the sending of data of individuals who did not belong to those companies to various collaborating entities of IBERMUTUA, and who, therefore, were not authorized to know such information.

From the documentation provided by the company, it is concluded that this breach was caused by an error in the programming of the notification sending to those entities through the IBERMUTUA platform, Ibermutua Digital Empresas/Asesorías.

Based on the complaints filed by the individuals whose data were affected by this breach, it is necessary to analyze whether IBERMUTUA ensured appropriate security of the data through the application of appropriate technical or organizational measures during the processing operations in which this breach occurred. That is, whether IBERMUTUA, as the data controller, complied with the obligations established by the GDPR for data controllers and, in particular, with the principle of integrity and confidentiality established in Article 5.1 of the GDPR.

In this regard, in its response, IBERMUTUA details a series of measures adopted by the company, mentioned earlier, which are both technical and organizational in nature, including the conduct of risk assessments.

It is appropriate to analyze the specific measures adopted concerning this particular case.

IBERMUTUA states that the breach is due to a programming error in the email sending conducted through the Ibermutua Digital Empresas/Asesorías platform, which has as recipients various collaborating entities of IBERMUTUA (companies and management firms). Specifically, users of this platform can choose to receive communications via email with

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
8/18

Information on economic benefits of workers corresponding to your entity and can configure certain parameters.

According to IBERMUTUA, there is a scheduled process (referred to as "notifier") in which an Excel file is prepared with the information and frequency that the users have configured. Once the file is prepared, an email is sent to the address that the user has configured, to which this Excel file is attached.

In this process, according to IBERMUTUA's response:

"The incident occurred due to a modification in the notifier. Due to human error, a line of code was commented out (when a line of code is commented out, it does not execute) which was responsible for resetting the attached Excel file in each new notification. Thus, on this occasion, each sending communicated the corresponding Excel file, and the previous ones generated in the same issuance of that day were added."

In its response, IBERMUTUA states that several technical measures were immediately adopted, among which it cites the following:

- Correction of the problem. The first action was to correct the error and establish a series of exhaustive tests to verify the correct functioning of any future changes, regardless of their magnitude.
- Restriction of attachments. A restriction was implemented so that the system does not allow the sending of multiple attachments in a single email. If such a situation is detected, the sending process stops automatically.
- Verification of the attachment ID. It is verified that the ID of the attached file corresponds to the recipient user before proceeding with the sending. If there are discrepancies, the sending is aborted.
- Pre-sending tests of email batches. Before sending emails, tests are carried out with a sample of 20 cases to ensure everything is in order. If any problem is detected, the sending is canceled."

Regarding these measures, it should be considered that they are basic security measures in relation to a procedure of the magnitude and characteristics of the present case, given that, as IBERMUTUA points out, the notification service within which the breach occurs involves sending a very high number of dispatches (an average of 250,000 monthly dispatches), which include personal data (some of which correspond to special categories, such as health data) relating to a very large number of interested parties.

It could be considered reasonable to have some control mechanism in these dispatches to prevent or detect errors in the configuration or in the sending procedure. In this regard, IBERMUTUA cites in its response basic measures such as the restriction on the number of attachments, a verification of the correspondence between the included data and the affiliation of the individuals to the recipient company, or the conducting of tests with a sample.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

9/18

Therefore, in accordance with the evidence available at this moment in the initiation of the sanctioning procedure, it is considered that the known facts could constitute an infringement, attributable to IBERMUTUA, for violation of the article transcribed above.

V

Qualification of the infringement of Article 5.1.f) of the GDPR and qualification for the purposes of prescription

Article 83.5 of the GDPR classifies as an administrative infringement the violation of the following article, which will be sanctioned, in accordance with paragraph 2, with administrative fines of up to 20,000,000 EUR or, in the case of a company, an amount equivalent to a maximum of 4% of the total annual global turnover of the previous financial year, opting for the higher amount:

"a) the basic principles for processing, including the conditions for consent in accordance with Articles 5, 6, 7, and 9;"

For its part, the LOPDGDD in its Article 71, Infringements, states that:

"Acts and conduct referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those contrary to this organic law, constitute infringements."

For the sole purposes of the prescription period, Article 72.1 of the LOPDGDD establishes the following:

"Based on what is established in Article 83.5 of Regulation (EU) 2016/679, the infringements that constitute a substantial violation of the articles mentioned therein are considered very serious and will prescribe after three years, particularly the following:

a) The processing of personal data violating the principles and guarantees established in Article 5 of Regulation (EU) 2016/679."

VI

Proposal for sanction

In order to determine the administrative fine to be imposed, the provisions of Articles 83.1 and 83.2 of the GDPR must be observed, which state:

"1. Each supervisory authority shall ensure that the imposition of administrative fines under this article for the infringements of this Regulation indicated in paragraphs 4, 9, and 6 are, in each individual case, effective, proportionate, and dissuasive.

2. Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure for the measures provided for in Article 58, paragraph 2, letters a) to h) and j). In deciding on the imposition of an administrative fine and its amount in each individual case, due consideration shall be given to:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/18

a) the nature, seriousness, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question as well as the number of affected parties and the level of damage and harm they have suffered;

b) the intent or negligence in the infringement;

c) any measures taken by the data controller or processor to mitigate the damage and harm suffered by the affected parties;

d) the degree of responsibility of the data controller or processor, considering the technical or organizational measures they have applied under Articles 25 and 32;

e) any previous infringement committed by the data controller or processor;

f) the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate any potential adverse effects of the infringement;

g) the categories of personal data affected by the infringement;

h) the manner in which the supervisory authority became aware of the infringement, particularly whether the data controller or processor reported the infringement and, if so, to what extent;

i) when the measures indicated in Article 58, paragraph 2, have been previously ordered against the data controller or processor in relation to the same matter, compliance with such measures;

j) adherence to codes of conduct under Article 40 or to certification mechanisms approved under Article 42, and

k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as the financial benefits obtained or the losses avoided, directly or indirectly, through the infringement."

For its part, Article 76 "Sanctions and corrective measures" of the LOPDGDD states:

"1. The sanctions provided for in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679 shall be applied taking into account the graduated criteria established in paragraph 2 of the aforementioned article.

2. In accordance with the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

a) The continued nature of the infringement.

b) The connection of the infringer's activity with the processing of personal data.

c) The benefits obtained as a result of the commission of the infringement.

d) The possibility that the conduct of the affected party may have induced the commission of the infringement.

e) The existence of a merger by absorption after the commission of the infringement, which cannot be attributed to the absorbing entity.

f) The impact on the rights of minors.

g) Having, when not mandatory, a data protection officer.

h) The voluntary submission by the data controller or processor to alternative dispute resolution mechanisms, in those cases.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

11/18

assumptions in which there are controversies between them and any interested party.”

In the present case, considering the seriousness of the possible infringement, especially taking into account the consequences that its commission causes to those affected, the imposition of a fine would be appropriate, in addition to the adoption of measures, if applicable.

The fine imposed must be, in each individual case, effective, proportionate, and dissuasive, in accordance with the provisions of Article 83.1 of the GDPR. To guarantee these principles, the business volume of IBERMUTUA (...) euros in the year 2023 is considered as a preliminary factor.

For the purpose of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available at this moment of the initiation of the sanctioning procedure, and without prejudice to what results from the instruction, it is considered appropriate to gradate the sanction to be imposed according to the following circumstances, contemplated in the aforementioned provisions.

As a preliminary matter, it is estimated that the following circumstances concur:

- The nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question, as well as the number of affected parties and the level of damage and harm they have suffered (Article 83.2, letter a), of the GDPR). Specifically, in this case, there is a high number of affected individuals, amounting to 3,395 persons.
- Regarding the categories of personal data affected by the infringement (Article 83.2, letter g), of the GDPR), it is noteworthy that the transmissions made included data provided for in Article 9 of the GDPR, such as health data (related to sick leave or accidents). Furthermore, the quantity of data sent for each affected individual is significant, considering that the violation of the right to privacy and the protection of personal data increases with the amount of data.

The balance of the circumstances contemplated in Article 83.2 of the GDPR, regarding the infringement committed by violating the provisions of Article 5.1.f) of the GDPR, allows for an initial administrative fine of 1,000,000.00 euros to be set.

VII

Corrective Measures

If the infringement is confirmed, the resolution issued may establish the corrective measures that the infringing entity must adopt to put an end to the non-compliance with personal data protection legislation, in this case, Article 5.1.f) of the GDPR, in accordance with the provisions of the aforementioned Article 58.2.d) of the GDPR, according to which each supervisory authority may “order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, where appropriate, in a specific manner and within a specified timeframe...”

Thus, the responsible entity may be required to adjust its actions to the personal data protection regulations, to the extent expressed in the previous Legal Grounds.

In this act, the alleged infringement committed and the facts that could lead to this possible violation of data protection regulations are established, from which it is clearly inferred what measures are to be adopted, without prejudice to the fact that the type of procedures, mechanisms, or specific instruments for implementing them corresponds to the sanctioned party, as it is the data controller who fully knows its organization and must decide, based on proactive responsibility and a risk-based approach, how to comply with the GDPR and the LOPDGDD.

However, in this case, regardless of the above, in accordance with the evidence available at this moment of the initiation of the sanctioning procedure, the resolution adopted may require IBERMUTUA to, within 3 months from the date of the enforceability of the resolution concluding this procedure, demonstrate the application of appropriate technical and organizational measures to prevent security breaches in the sending of communications such as those subject to this procedure, such as limiting the number of files, including filters or mechanisms that relate the individuals whose data is the subject

of the communication with the entities authorized to know their data or conducting prior tests before the transmissions.

The imposition of these measures is compatible with the sanction consisting of an administrative fine, as provided in Article 83.2 of the GDPR.

It is noted that failure to comply with the possible order to adopt measures imposed by this agency in the resolution of this sanctioning procedure may be considered an administrative infringement in accordance with the provisions of the GDPR, classified as an infringement in its Articles 83.5 and 83.6, which may motivate such conduct to open a further administrative sanctioning procedure.

It is also reminded that neither the acknowledgment of the infringement committed nor, where applicable, the voluntary payment of the proposed amounts exempts the obligation to adopt the pertinent measures to cease the conduct or correct the effects of the infringement committed and to demonstrate to this AEPD compliance with that obligation.

Therefore, in light of the above, by the Presidency of the Spanish Agency for Data Protection, IT IS AGREED:

FIRST: TO INITIATE SANCTIONING PROCEDURE against IBERMUTUA MUTUA COLABORADORA CON LA SEGURIDAD SOCIAL N° 274, with NIF G81939217, at

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

13/18

the alleged infringement of Article 5.1.f) of the GDPR, classified under Article 83.5 of the GDPR.

SECOND: APPOINT R.R.R. as the instructor and S.S.S. as the secretary, indicating that they may be challenged, if applicable, in accordance with the provisions of Articles 23 and 24 of Law 40/2015, of October 1, on the Legal Regime of the Public Sector (LRJSP).

THIRD: INCORPORATE into the file, for evidentiary purposes, the complaint filed by the claimant and its documentation, as well as the documents obtained and generated by the General Subdirectorate of Data Inspection in the proceedings prior to the initiation of this sanctioning procedure.

FOURTH: THAT for the purposes provided in Article 64.2 b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, the sanction that may correspond would be an administrative fine of 1,000,000.00 euros, without prejudice to what results from the instruction.

FIFTH: NOTIFY this agreement to IBERMUTUA MUTUA COLABORADORA CON LA SEGURIDAD SOCIAL N° 274, with NIF G81939217, granting a hearing period of ten working days for it to submit allegations and present any evidence it deems appropriate. In its written allegations, it must provide its NIF and the procedure number that appears in the heading of this document.

In accordance with the provisions of Article 85 of the LPACAP, it may acknowledge its responsibility within the period granted for the formulation of allegations to this initiation agreement; this will entail a reduction of 20% of the sanction that may be imposed in this procedure. With the application of this reduction, the sanction would be set at 800,000.00 euros, resolving the procedure with the imposition of this sanction.

Similarly, it may, at any time prior to the resolution of this procedure, voluntarily pay the proposed sanction, which will imply a reduction of 20% of its amount. With the application of this reduction, the sanction would be set at 800,000.00 euros, and its payment will imply the termination of the procedure, without prejudice to the imposition of the corresponding measures.

The reduction for the voluntary payment of the sanction is cumulative with the one corresponding to the acknowledgment of responsibility, provided that this acknowledgment of responsibility is made within the period granted to formulate allegations to the opening of the procedure. The voluntary payment of the amount referred to in the previous paragraph may be made at any time prior to the resolution. In this case, if both reductions were to be applied, the amount of the sanction would be set at 600,000.00 euros.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

In any case, the effectiveness of either of the two reductions mentioned will be conditioned upon the express withdrawal or renunciation of any administrative action or appeal against the sanction. For these purposes, in the event of opting for either of them, a formal communication of the withdrawal or renunciation of any administrative action or appeal against the sanction must be sent to the General Subdirectorate of Data Inspection, indicating which of the two reductions is being accepted or if both are being accepted.

In the event that you choose to proceed with the voluntary payment of any of the amounts indicated above (800,000.00 euros or 600,000.00 euros), you must make the payment by depositing it into account No. IBAN: ES00-0000-0000-0000-0000 (BIC/SWIFT Code: CAIXESBBXXX) opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A., indicating in the concept the reference number of the procedure that appears in the heading of this document and the reason for the reduction of the amount to which you are adhering.

Furthermore, you must send the proof of payment to the General Subdirectorate of Inspection along with the formal communication of the withdrawal or renunciation of any administrative action or appeal against the sanction in order to continue with the procedure in accordance with the amount deposited. In compliance with Articles 14, 41, and 43 of the LPACAP, it is warned that, henceforth, notifications sent to you will be carried out exclusively electronically, through the Single Enabled Electronic Address (dehu.redsara.es) and the Electronic Headquarters (sedeagpd.gob.es), and that, if you do not access them, your rejection will be recorded in the file, considering the procedure completed and continuing with the process. You are informed that you can identify an email address to this Agency to receive notice of the availability of notifications and that the lack of this notice will not prevent the notification from being considered fully valid.

In accordance with the provisions of Article 76.4 of the LOPDGDD, if the amount of the imposed sanction exceeds one million euros, the information identifying the offender, the infringement committed, and the amount of the imposed sanction will be published in the Official State Gazette. Finally, it is noted that according to the provisions of Article 112.1 of the LPACAP, there is no administrative appeal against this act.

1479-111224

Olga Pérez Sanjuán

The Deputy Director General of Data Inspection, in accordance with Article 48.2 LOPDGDD, due to the vacancy of the Presidency and Deputy Presidency.

>>

SECOND: On February 17, 2025, IBERMUTUA proceeded to pay the sanction in the amount of 600,000.00 euros making use of the two reductions provided for in the previously transcribed initiation agreement, which implies the acknowledgment of responsibility in relation to the facts referred to in the initiation agreement and its legal qualification.

THIRD: IBERMUTUA has expressly renounced any administrative action or appeal against the sanction.

FOURTH: In the initiation agreement transcribed above, it was indicated that, if the infringement is confirmed, the responsible party could be ordered to adopt appropriate measures to adjust its actions to the regulations mentioned in this act, in accordance with the provisions of the aforementioned Article 58.2 d) of the GDPR, according to which each supervisory authority may "order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, where appropriate, in a specific manner and within a specified period...".

Having acknowledged the responsibility for the infringement, the imposition of the measures included in the initiation agreement is appropriate.

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47,

48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and the guarantee of digital rights (hereinafter, LOPDGDD), the Presidency of the Spanish Agency for Data Protection is competent to resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued for its development, and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Termination of the procedure

Article 85 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), under the heading "Termination in sanctioning procedures" provides as follows:

"1. Once a sanctioning procedure has been initiated, if the offender acknowledges their responsibility, the procedure may be resolved with the imposition of the appropriate sanction.

2. When the sanction is solely pecuniary or when a pecuniary sanction and another non-pecuniary sanction can be imposed, but the justification has been provided..."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

16/18

In the event of the inadmissibility of the second, voluntary payment by the presumed responsible party, at any time prior to the resolution, will imply the termination of the procedure, except regarding the restoration of the altered situation or the determination of compensation for the damages caused by the commission of the infringement.

3. In both cases, when the sanction is solely of a pecuniary nature, the competent authority to resolve the procedure will apply reductions of at least 20% on the amount of the proposed sanction, which are cumulative. The aforementioned reductions must be specified in the notification of the initiation of the procedure, and their effectiveness will be conditioned upon the withdrawal or renunciation of any action or administrative appeal against the sanction. The percentage of reduction provided in this section may be increased by regulation.

III

Voluntary Payment and Acknowledgment of Responsibility

In accordance with the provisions of the aforementioned Article 85 of the LPACAP, the notified initiation agreement informed about the possibility of acknowledging responsibility and making the voluntary payment of the proposed sanction, which would entail two cumulative reductions of 20% each. With the application of these two reductions, the sanction would be established at 600,000.00 euros, and its payment would imply the termination of the procedure, without prejudice to the imposition of the corresponding measures.

After the notification of the aforementioned initiation agreement, IBERMUTUA has proceeded to acknowledge responsibility and make the voluntary payment of the sanction, availing itself of the two reductions provided and expressly waiving any action or administrative appeal.

It should be noted that, in accordance with the provisions of the LPACAP, as well as the jurisprudence of the Supreme Court in this matter, the exercise of voluntary payment by the presumed responsible party does not exempt the administration from the obligation to resolve and notify all procedures, regardless of their form of initiation. Likewise, Article 88 of the aforementioned regulation establishes that the resolution that concludes the procedure will decide all issues raised by the interested parties and those arising from it.

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of the sanctions whose existence has been established, the Presidency of the Spanish Agency for Data Protection RESOLVES:

C/ Jorge Juan, 6

www.aepd.es
28001 – Madrid
sedeagpd.gob.es

17/18

FIRST: TO DECLARE the commission of the infringements and TO CONFIRM the sanctions determined in the dispositive part of the initiation agreement transcribed in this resolution. The sum of the aforementioned amounts yields a total of 1,000,000.00 euros.

After IBERMUTUA, MUTUA COLABORADORA CON LA SEGURIDAD SOCIAL NUM.274 has proceeded with the prompt payment and acknowledgment of responsibility, it is hereby resolved, pursuant to Article 85 of the LPACAP, to reduce the total mentioned by 40%, which results in a definitive amount of 600,000.00 euros.

SECOND: TO DECLARE the termination of procedure EXP202412881, in accordance with the provisions of Article 85 of the LPACAP.

THIRD: TO ORDER IBERMUTUA, MUTUA COLABORADORA CON LA SEGURIDAD SOCIAL NUM.274 to notify the Agency within 3 months from the date this resolution becomes final and enforceable, of the adoption of the measures described in the legal grounds of the initiation agreement transcribed in this resolution.

FOURTH: TO NOTIFY this resolution to IBERMUTUA, MUTUA COLABORADORA CON LA SEGURIDAD SOCIAL NUM.274.

FIFTH: In accordance with the provisions of Article 85 of the LPACAP, which conditions the reduction for voluntary payment and acknowledgment of responsibility to the withdrawal or renunciation of any action or administrative appeal, the present authority accepts the express waiver stated by IBERMUTUA, MUTUA COLABORADORA CON LA SEGURIDAD SOCIAL NUM.274, thus precluding the filing of a voluntary appeal for reconsideration against this resolution, all without prejudice to the possibility of resorting to the contentious-administrative jurisdiction.

Consequently, taking into account the provisions of Article 90 of the LPACAP, since no administrative appeal is possible due to the express waiver, this resolution will be final and fully enforceable from the date of its notification.

However, in accordance with the provisions of Article 90.3.a) of the LPACAP, the final resolution may be provisionally suspended in the administrative route if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Agency's Electronic Registry

[<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the contentious-administrative appeal. If the Agency does not receive knowledge of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, the provisional suspension will be considered terminated.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

18/18

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

1259-180225

Olga Pérez Sanjuán

The Deputy Director General of Data Inspection, in accordance with Article 48.2 LOPDGDD, due to the vacancy of the positions of President and Deputy

C/ Jorge Juan, 6
www.aepd.es

28001 – Madrid
sedeagpd.gob.es